

CUADERNILLO DE ESTUDIO

CLASE 4

*“Criptografía aplicada
a negocios digitales”*

⑩ Incluye actividad con Inteligencia Artificial

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Unidad: Cierre de Unidad 1

Datos del/la estudiante

Nombre y apellido: _____ Grupo N.º: _____

Correo: _____ Fecha: _____

Índice

1. ¿Por qué la criptografía sostiene la confianza digital?	2
2. Cifrado simétrico y asimétrico	3
2.1. Cifrado simétrico: una sola clave	3
2.2. Cifrado asimétrico: dos claves (pública y privada)	3
2.3. Comparación rápida	4
3. Hashing: la huella digital de los datos	5
3.1. ¿Por qué no es lo mismo que cifrar?	5
3.2. SHA-256 en la práctica	5
3.3. ¿Por qué nunca almacenar contraseñas en texto plano?	5
4. HTTPS, certificados y firma digital	6
4.1. HTTPS: el candado del navegador	6
4.2. Firma digital: autenticidad + integridad	6
5. Casos de uso: ¿dónde vive la criptografía en tu negocio?	7
6. Actividad práctica: Taller de Hashing	8
7. Actividad con IA: Explicar, auditar y verificar	10
8. Glosario criptográfico mínimo	12
9. Cierre de Unidad 1: ¿Qué nos llevamos?	13
10. Espacio para notas y reflexiones	14

1. ¿Por qué la criptografía sostiene la confianza digital?

En las clases anteriores vimos **qué** proteger (activos, pilares CID) y **contra qué** (amenazas). Hoy vamos a ver **cómo** se protege la información en tránsito y en reposo: la **criptografía**.

[title=Conexión con lo anterior] Recordemos la demo de la Clase 1: la página accedió a tu cámara y transmitió la imagen a un panel de administración. Si esa transmisión hubiera estado **cifrada**, un tercero no habría podido interceptarla. Si el panel hubiera requerido **autenticación fuerte**, no cualquiera habría podido verla. La criptografía es la base técnica que hace posibles esos controles.

Sin criptografía no hay e-commerce, no hay fintech, no hay home banking. Cada vez que un cliente ingresa los datos de su tarjeta en tu tienda online, confía en que esa información viaja protegida. Esa protección es criptografía.

Objetivos de esta clase:

1. Comprender qué es **cifrado** y **hashing**, y por qué sostienen la confianza digital (HTTPS, contraseñas, firma digital).
2. Practicar el uso **crítico** de IA generativa para explicar conceptos técnicos.

2. Cifrado simétrico y asimétrico

Definición

Cifrar es transformar información legible (texto plano) en una forma ilegible (texto cifrado) usando una **clave**, de modo que solo quien posee la clave adecuada pueda revertir el proceso.

2.1 Cifrado simétrico: una sola clave

[title=Analogía del candado] Imaginá una caja fuerte con **una sola llave**. El que guarda el documento usa esa llave para cerrar la caja. El que necesita leer el documento debe tener **la misma llave** para abrirla.

Problema: ¿Cómo le hago llegar la llave al destinatario sin que alguien la copie en el camino?

Características:

- Una única clave para cifrar y descifrar.
- Muy rápido y eficiente para grandes volúmenes de datos.
- El desafío es la **distribución segura de la clave**.

En un negocio digital: Cifrar la base de datos de clientes en el servidor. El servidor cifra al guardar y descifra al leer, usando la misma clave que está almacenada de forma segura (idealmente en un módulo HSM o un gestor de secretos como AWS Secrets Manager).

2.2 Cifrado asimétrico: dos claves (pública y privada)

[title=Analogía del buzón] Imaginá un buzón público en la calle. **Cualquiera** puede meter una carta por la ranura (usar la **clave pública** para cifrar), pero **solo el dueño del buzón** tiene la llave para abrirlo y sacar las cartas (usar la **clave privada** para descifrar).

Ventaja: No necesito que el remitente tenga una llave secreta; solo necesita saber que el buzón existe.

Características:

- Par de claves: una **pública** (se comparte) y una **privada** (se guarda en secreto).
- Lo que cifra una, solo lo descifra la otra.
- Más lento que el simétrico (se usa para establecer la conexión, no para cifrar todo el tráfico).

En un negocio digital: Cuando un cliente se conecta a tu e-commerce por HTTPS, su navegador usa la **clave pública** de tu servidor para negociar una clave de sesión simétrica. A partir de ahí, toda la comunicación viaja cifrada con esa clave simétrica (rápida y segura).

2.3 Comparación rápida

	Simétrico	Asimétrico
Claves	Una sola (compartida)	Par: pública + privada
Velocidad	Muy rápido	Más lento
Uso típico	Cifrar datos en reposo, sesiones HTTPS	Establecer conexión, firma digital
Desafío	¿Cómo comparto la clave de forma segura?	¿Cómo sé que la clave pública es realmente de quien dice ser? (certificados)
Ejemplo real	AES-256 (base de datos, discos)	RSA, ECC (HTTPS, firma digital)

En la práctica se usan juntos: HTTPS usa cifrado asimétrico para “presentarse” y negociar, y luego simétrico para transmitir los datos rápido. Es un sistema híbrido.

3. Hashing: la huella digital de los datos

Definición

Una **función hash** toma cualquier dato (una contraseña, un archivo, un documento) y produce una cadena de caracteres de longitud fija, única para ese dato. Es **irreversible**: no se puede “descifrar” un hash para obtener el dato original.

3.1 ¿Por qué no es lo mismo que cifrar?

	Cifrado	Hash
¿Reversible?	Sí (con la clave correcta)	No (irreversible)
Propósito	Proteger datos que necesito leer después	Verificar integridad; almacenar contraseñas
Salida	Texto cifrado de longitud variable	Cadena de longitud fija (ej. 64 chars en SHA-256)
Ejemplo	Cifrar un contrato PDF	Guardar la contraseña del usuario en la base de datos

3.2 SHA-256 en la práctica

Si aplico SHA-256 a la palabra Hola:

Hola -> 7426db3a45...

Si aplico SHA-256 a hola (minúscula):

hola -> 11254a2fc8...

Un solo bit de diferencia produce un hash completamente distinto. Eso lo hace ideal para detectar si un archivo fue modificado.

3.3 ¿Por qué nunca almacenar contraseñas en texto plano?

Si tu e-commerce guarda las contraseñas de los usuarios en texto plano y un atacante roba la base de datos, **obtiene todas las contraseñas directamente**.

Si en cambio guardás el **hash** de cada contraseña, el atacante obtiene cadenas ilegibles. Para “adivinar” la contraseña original tendría que probar millones de combinaciones una por una (ataque de fuerza bruta o diccionario).

Regla: Las contraseñas se almacenan hasheadas (idealmente con *salt* y funciones lentas como bcrypt o Argon2). Nunca en texto plano. Nunca con hash simple como MD5.

4. HTTPS, certificados y firma digital

4.1 HTTPS: el candado del navegador

[title=¿Qué pasa cuando ves el candadito?] Cuando un cliente entra a `https://mitienda.com`, ocurre esto:

1. El navegador pregunta al servidor: “¿Quién sos?”.
2. El servidor responde con su **certificado digital** (emitido por una Autoridad Certificante como Let’s Encrypt, DigiCert, etc.).
3. El navegador verifica que el certificado es válido y confiable.
4. Se negocia una **clave de sesión simétrica** usando criptografía asimétrica.
5. Toda la comunicación posterior viaja **cifrada** con esa clave.

Resultado: Nadie en el medio (ni en el WiFi del café) puede leer los datos de la tarjeta del cliente.

Para tu negocio digital: Si tu e-commerce no tiene HTTPS, los navegadores muestran “No seguro” en rojo. Los clientes no compran. Google te penaliza en el ranking. Es el mínimo indispensable.

4.2 Firma digital: autenticidad + integridad

Definición

La **firma digital** es el equivalente criptográfico de una firma manuscrita, pero más poderosa: garantiza **autenticidad** (quién firmó) e **integridad** (que el documento no fue modificado después de firmarse).

¿Cómo funciona (conceptualmente)?

1. Se calcula el **hash** del documento.
2. Se cifra ese hash con la **clave privada** del firmante → eso es la firma.
3. El receptor calcula el hash del documento recibido y lo compara con el hash descifrado (usando la **clave pública** del firmante).
4. Si coinciden → el documento es auténtico e íntegro.

En fintech: Un contrato de préstamo digital se firma electrónicamente. Si alguien modifica una coma del PDF después de la firma, la verificación falla y se detecta la alteración.

5. Casos de uso: ¿dónde vive la criptografía en tu negocio?

Escenario	Criptografía aplicada	Pilar CID
Cliente paga con tarjeta en un e-commerce	HTTPS/TLS cifra la conexión; la pasarela de pago tokeniza el número de tarjeta	Confidencialidad
Almacenamiento de contraseñas de usuarios	Hash con bcrypt/Argon2 + salt único por usuario	Confidencialidad
Factura electrónica o contrato digital	Firma digital con clave privada del emisor	Integridad + Autenticidad
Backup de la base de datos	Cifrado simétrico (AES-256) del archivo de backup	Confidencialidad
Actualización de software al cliente	Hash SHA-256 del instalador para verificar que no fue adulterado	Integridad
App de mensajería (WhatsApp, Signal)	Cifrado de extremo a extremo (E2EE): solo emisor y receptor pueden leer	Confidencialidad
Login con 2FA	Código TOTP generado con algoritmo HMAC (basado en hash)	Confidencialidad + Disponibilidad

[title=Pregunta para reflexionar] Si tu negocio digital no implementa ninguna de estas medidas, ¿qué pilares CID estás dejando desprotegidos? ¿Qué impacto tendría una brecha?

6. Actividad práctica: Taller de Hashing

[title=Generar y analizar hashes SHA-256]

Paso 1: Ingresen a una herramienta online de hashing, por ejemplo:

<https://passwordsgenerator.net/sha256-hash-generator/>

(o busquen “SHA-256 online generator” en el navegador)

Paso 2: Generen el hash de las siguientes tres contraseñas y completen la tabla:

Contraseña	Hash SHA-256 resultante
123456	
MiEmpresa2024	
Xk9#mL2\$pQ7@vR	

Paso 3: Respondan en grupo:

¿Qué observan sobre la longitud de los tres hashes? ¿Son todos iguales en largo? ¿Por qué?

Si cambio una sola letra de “MiEmpresa2024” a “MiEmpresa2025”, ¿el hash se parece al anterior o es totalmente diferente? ¿Por qué importa esto?

¿Pueden “revertir” el hash para obtener la contraseña original? ¿Qué implica esto para el almacenamiento seguro?

¿Por qué la contraseña “123456” sigue siendo vulnerable aunque la guarde hasheada?

(Pista: piensen en ataques de diccionario y rainbow tables)

7. Actividad con IA: Explicar, auditar y verificar

Objetivo: Usar una IA generativa como asistente de estudio y luego **auditar críticamente** su respuesta. La IA no reemplaza el criterio; lo complementa.

Consigna grupal:

1. Elijan una IA generativa (ChatGPT, Claude, Gemini, la que prefieran).
2. Pídanle exactamente este prompt (o una versión propia):

“Explicá en lenguaje simple, como si le hablaras a un estudiante de negocios digitales sin conocimientos técnicos previos, cómo funciona el cifrado de extremo a extremo en una app de mensajería como WhatsApp. Después, generá un mini-glosario de 8 términos criptográficos clave con definiciones de una línea cada una.”

3. **Copien** la respuesta completa de la IA en el espacio de abajo (o imprímanla).
4. **Auditen** la respuesta contrastándola con lo que vieron en clase y con una fuente confiable (material de cátedra, ISO/IEC 27000, o una búsqueda en sitios como EFF, Cloudflare Learning, etc.).
5. **Marquen** con una ✓ lo que es correcto, una ✗ lo que es impreciso o incorrecto, y una ☹ lo que está excesivamente simplificado.
6. Redacten un **informe de verificación de una página** que incluya:
 - ¿Qué afirmaciones de la IA eran correctas?
 - ¿Qué afirmaciones eran imprecisas o incorrectas?
 - ¿Qué simplificó de más y perdió matiz importante?
 - ¿Qué corregirían o agregarían?

[title=Espacio para pegar la respuesta de la IA y auditarla]

Pegar aquí la respuesta de la IA (o resumen):

Hallazgos de la auditoría (¿qué es correcto? ¿qué es impreciso? ¿qué falta?):

[title=Reglas del curso para el uso de IA]

1. **Transparencia:** declarar qué herramienta usaron, para qué y con qué prompt.
2. **Verificación obligatoria:** ninguna salida de IA se entrega “tal cual”.
3. **Responsabilidad:** el grupo es responsable del resultado final, use o no IA.

8. Glosario criptográfico mínimo

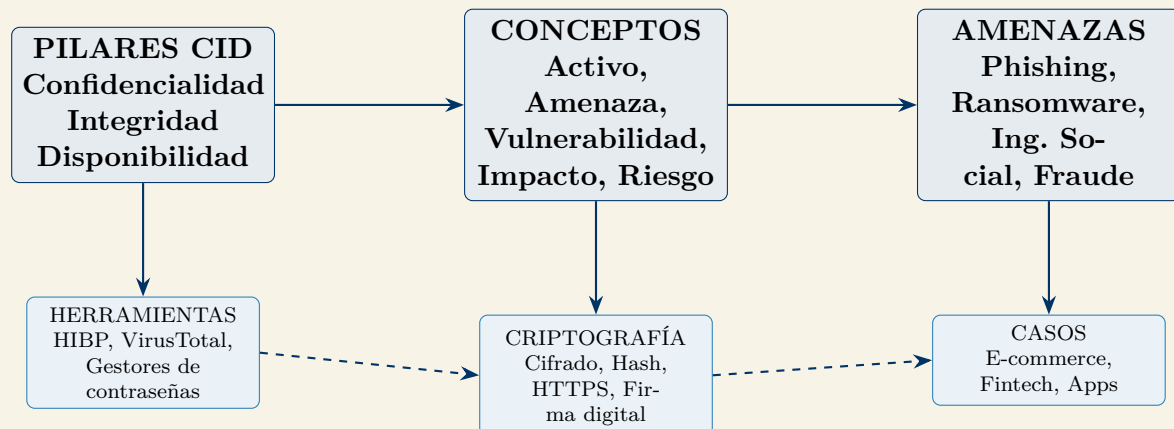
Término	Definición en una línea
Texto plano	Información legible antes de ser cifrada.
Texto cifrado	Información ilegible resultado del cifrado.
Clave simétrica	Única clave compartida para cifrar y descifrar.
Clave pública	Parte del par asimétrico que se comparte libremente.
Clave privada	Parte del par asimétrico que se guarda en secreto.
Hash	Función irreversible que produce una cadena fija desde cualquier dato.
SHA-256	Algoritmo hash que produce una cadena de 256 bits (64 caracteres hex).
Sal (salt)	Valor aleatorio agregado antes de hashear para evitar ataques de diccionario.
HTTPS / TLS	Protocolo que cifra la comunicación entre navegador y servidor.
Certificado digital	Documento que vincula una clave pública con una identidad verificada.
Firma digital	Hash cifrado con clave privada; garantiza autoría e integridad.
Cifrado E2EE	Cifrado de extremo a extremo: solo emisor y receptor pueden leer.
Rainbow table	Tabla precomputada de hashes usada para revertir hashes débiles.
bcrypt / Argon2	Funciones hash lentas diseñadas para almacenar contraseñas.

9. Cierre de Unidad 1: ¿Qué nos llevamos?

Con esta clase **cerramos formalmente la Unidad 1**. Hagamos un repaso de todo lo construido:

Cierre de Unidad

[title=Mapa de la Unidad 1]



En la Unidad 1 aprendimos a:

- Identificar activos y clasificar riesgos usando los pilares CID.
- Reconocer las amenazas más comunes para negocios digitales.
- Usar herramientas gratuitas de verificación y protección.
- Comprender cómo la criptografía habilita la confianza digital.
- Usar IA generativa de forma **crítica y verificada**.

Lo que viene (Unidad 2): Gestión de riesgos formal. Vamos a pasar de “entender las amenazas” a **medirlas, priorizarlas y tratarlas** con metodología (matriz P×I, BIA, controles, ISO 27001).

10. Espacio para notas y reflexiones

Usá este espacio para anotar dudas, ideas para tu TP Integrador, o conexiones entre la criptografía y el negocio digital que eligió tu grupo.

[title=Puente hacia la Clase 5] La próxima clase arrancamos la **Unidad 2: Gestión de Riesgos**.

Pregunta disparadora para pensar antes de la próxima clase:

Si tuvieras que proteger tu negocio digital con presupuesto para solo 3 controles de seguridad, ¿cuáles elegirías y por qué?